



Web Cache Deception Vulnerabilities

Web Cache Deception Vulnerabilities là một lỗ hổng bảo mật xảy ra khi một ứng dụng web cho phép kẻ tấn công lưu trữ thông tin nhạy cảm hoặc độc hại trong bộ nhớ cache của web server, dẫn đến việc phục vụ nội dung không mong muốn cho người dùng hợp lệ. Dưới đây là trình bày chi tiết về loại lỗ hổng này, bao gồm định nghĩa, cách thức hoạt động, các ví dụ thực tế, lý do tại sao nó lại nguy hiểm, và vai trò của **URL Mapping**.

I. Định Nghĩa Web Cache Deception

Web Cache Deception là một kỹ thuật tấn công mà trong đó kẻ tấn công tận dụng sự thiếu sót trong cấu hình bộ nhớ cache của ứng dụng web để lưu trữ nội dung nhạy cảm hoặc độc hại. Điều này xảy ra khi nội dung không nên được cache lại được lưu trữ và phục vụ cho người dùng khác.

II. Cách Thức Hoạt Động của Tấn Công

1. **Tạo URL Độc Hại:** Kẻ tấn công sẽ tạo ra một URL mà ứng dụng web không kiểm tra kỹ lưỡng. Ví dụ: <https://example.com/profile.php?id=123> có thể là một trang chứa thông tin cá nhân.
2. **Lưu Trữ Nội Dung:** Kẻ tấn công gửi yêu cầu đến URL đó với các tham số mà ứng dụng không kiểm soát tốt. Hệ thống cache lưu trữ nội dung của URL mà không biết rằng nó có thể chứa thông tin nhạy cảm.
3. **Phục Vụ Nội Dung Từ Cache:** Khi người dùng hợp lệ khác (không phải kẻ tấn công) truy cập cùng một URL hoặc một URL tương tự, hệ thống cache sẽ phục vụ nội dung đã được lưu trữ từ cache, cho phép người dùng không có quyền truy cập nhận được thông tin nhạy cảm.

III. Tại Sao Tấn Công Web Cache Deception Lại Nguy Hiểm?



- **Rò Rỉ Thông Tin Nhạy Cảm:** Nếu kẻ tấn công thành công trong việc lưu trữ nội dung nhạy cảm (như trang cá nhân hoặc thông tin tài khoản), người dùng khác có thể vô tình truy cập các thông tin này.
- **Giả Mạo Nội Dung:** Kẻ tấn công có thể thay thế nội dung hợp lệ bằng nội dung độc hại, dẫn đến việc người dùng bị lừa đảo hoặc bị tấn công.
- **Khó Phát Hiện:** Các lỗ hổng này có thể rất khó phát hiện, vì nội dung độc hại có thể chỉ được phục vụ khi người dùng hợp lệ truy cập URL cụ thể.

IV. Vai Trò của URL Mapping

URL Mapping liên quan đến việc ánh xạ các URL đến nội dung cụ thể trong ứng dụng web. Khi một ứng dụng sử dụng URL Mapping không chính xác, kẻ tấn công có thể tạo ra các URL có thể dẫn đến nội dung không được bảo vệ, dẫn đến việc nội dung nhạy cảm được lưu trữ trong cache. Các vấn đề liên quan đến URL Mapping có thể bao gồm:

- **Thiếu Kiểm Soát Truy Cập:** Nếu các URL không được ánh xạ chính xác đến các tài nguyên tương ứng, người dùng có thể vô tình nhận được các phiên bản nội dung mà họ không có quyền truy cập.
- **Cache Không Chính Xác:** Nếu một URL nhạy cảm được ánh xạ không chính xác hoặc không có chính sách cache rõ ràng, nội dung của URL đó có thể được lưu trữ và phục vụ cho người dùng khác.

V. Ví Dụ Thực Tế về Tấn Công Web Cache Deception

- **Tấn công đối với các trang đăng nhập:** Nếu một trang đăng nhập (chẳng hạn như <https://example.com/login>) không được cấu hình chính xác và cho phép lưu trữ trong cache, kẻ tấn công có thể gửi một yêu cầu giả mạo, và nếu trang đăng nhập đó bị lưu trữ trong cache, người dùng khác có thể nhận được một phiên bản trang đã được sửa đổi hoặc chứa mã độc.
- **Tấn công vào API:** Kẻ tấn công có thể gửi yêu cầu đến một endpoint API (như <https://api.example.com/user>) mà không có xác thực thích hợp. Nếu nội dung



của endpoint này bị lưu trong cache, các thông tin nhạy cảm về người dùng có thể được phục vụ cho những người dùng khác không có quyền truy cập.

VI. Cách Bảo Vệ Chống Tấn Công Web Cache Deception

- **Cấu Hình Cache Chính Xác:** Đảm bảo rằng các URL nhạy cảm không được cache. Sử dụng các tiêu đề như **Cache-Control: no-store** để ngăn chặn lưu trữ.
- **Kiểm Tra Xác Thực và Phân Quyền:** Đảm bảo rằng tất cả các yêu cầu đến các trang hoặc tài nguyên nhạy cảm đều được kiểm tra xác thực và phân quyền trước khi được phục vụ.
- **Sử Dụng URL Độc Nhất:** Để tránh lưu trữ nội dung nhạy cảm, sử dụng các tham số duy nhất trong URL để phân biệt giữa các phiên người dùng khác nhau.

VII. Tham Khảo

<https://portswigger.net/web-security/learning-paths/web-cache-deception>

Mọi thắc mắc hay ý kiến đóng góp vui lòng liên hệ :

Email : r3dctf.info@gmail.com

@Design by R3D CTF Team